

Vanteloq Identity and Access Control Evidence

OWNER VERIFICATION

Upload for access-control evidence. Critical-system MFA remains conditional until every administrator is verified.

Prepared: 2026-08-13 Owner: Hussien Issa, Owner and Security Lead Evidence status: Application controls verified; critical administrator MFA inventory requires owner completion.

Purpose and scope

This document supports the Access control and authentication section of Plaid's security questionnaire. It describes Vanteloq's current production application controls and identifies the separate evidence required for consumer MFA and for administrator access to critical systems.

Access control architecture

Vanteloq uses Supabase Auth as the authoritative identity provider and Cloudflare as the application edge. The browser is never authoritative for a role, organization, entitlement, permission, or MFA decision.

Every protected server request:

- 1 validates the signed Supabase bearer token;
- 2 binds the immutable Supabase subject to an active Vanteloq user and organization membership;
- 3 resolves the user's role and permissions on the server;
- 4 enforces the requested organization and location boundary;
- 5 requires an AAL2 session for protected application and integration actions; and
- 6 rejects absent, expired, cross-tenant, or insufficiently privileged access.

Client-supplied organization identifiers, roles, prices, permissions, or decoded-but-unverified claims are never authoritative. Hidden navigation is only a usability control; each protected API independently enforces authorization.

Plaid questionnaire selections

For the question asking which controls limit access to production assets and sensitive data, the currently supported selections are:

- **Role-based access control (RBAC).** Vanteloq uses server-side membership, role, permission, organization, and location checks.
- **Use of OAuth tokens or TLS certificates for non-human authentication.** Provider integrations use scoped OAuth credentials or authenticated service requests. Secrets remain server-side and are encrypted where stored.

Select **Defined and documented access policy** only after the Information Security Policy has been signed and adopted. Select **Periodic access reviews and audits are performed** only after completing and retaining the first dated quarterly access review. Do not select automated de-provisioning, zero-trust architecture, or centralized identity and access management unless those controls are implemented and evidenced.

Consumer MFA before Plaid Link

Vanteloq uses Supabase time-based one-time password authentication and requires a confirmed AAL2 session before protected Plaid Link actions. TOTP is multi-factor authentication, but it is not phishing-resistant.

Questionnaire answer:

Yes - Non-phishing-resistant multi-factor authentication is performed.

Acceptable screenshot evidence is the normal six-digit authenticator challenge displayed after password sign-in, or a post-challenge security status page that clearly shows the provider-managed MFA boundary. The screenshot must not contain the enrollment QR code, TOTP seed, recovery code, access token, browser storage, developer console, or password.

MFA for critical systems

Critical systems in scope include Cloudflare, Supabase, Plaid, source control, and production email. The questionnaire answer can be **Yes - Non-phishing-resistant multi-factor authentication is performed** only after MFA has been verified for every applicable administrator. If any critical administrator can use password-only access, answer **No** and remediate it first.

Keep one screenshot or provider-generated security report for each critical system. Each item should show the provider name, administrator identity or redacted account reference, MFA enabled state, factor type, and verification date. Do not capture or store secrets.

Critical administrator MFA inventory

Provider	Administrator	Role	Factor type	MFA verified date	Reviewer	Evidence filename	Status
Cloudflare	_____	_____	_____	_____	_____	_____	Open
Supabase	_____	_____	_____	_____	_____	_____	Open
Plaid	_____	_____	_____	_____	_____	_____	Open
Source control	_____	_____	_____	_____	_____	_____	Open
Production email	_____	_____	_____	_____	_____	_____	Open

Session and credential safeguards

- Sign-in is same-origin, Cloudflare Turnstile-protected, body-bounded, and rate-limited.
- Passwords are sent only to Supabase Auth and are never persisted by Vanteloq.
- Application APIs require a valid bearer token and confirmed AAL2 session.
- Supabase access tokens are short-lived; refresh-token rotation and reuse detection are enabled.
- Password confirmation and recovery use PKCE.
- Business data and memory remain server-side and tenant-scoped; they are not copied into browser storage.
- The Worker enforces content security policy, frame denial, HSTS, no-sniff, no-store API responses, and same-origin mutation checks.

Technical evidence map

Control	Evidence
Supabase token validation and immutable identity binding	server/authorization.ts, server/api.ts, authentication boundary tests
Server-side RBAC and tenant isolation	server/permissions.ts, organization membership checks, tenant boundary tests
AAL2 enforcement before Plaid actions	Protected Plaid routes, Supabase MFA flow, Plaid lifecycle tests
Consumer MFA selection	Supabase TOTP/AAL2 configuration and a safe six-digit challenge screenshot
Non-human authentication	OAuth state-bound provider integrations and authenticated service endpoints
Login protections	Turnstile, same-origin checks, rate limits, bounded requests, PKCE, refresh-token rotation
Critical-system MFA	Completed administrator MFA inventory plus one safe provider screenshot per critical system

Verification results

On 2026-08-13, the Vanteloq security boundary suite reported 27 passing tests. The Plaid lifecycle, consent, encryption, and deletion suite reported 15 passing tests. TypeScript checking passed, and the production dependency audit reported zero known vulnerabilities after the patched lockfile resolution.

Owner attestation

I confirm that this evidence describes the current Vanteloq access control boundary. I understand that the critical-system MFA questionnaire answer remains conditional until every administrator listed above has been verified and the evidence retained.

Owner name: Hussien Issa Signature: _____ Date: _____